

DPIA — KEYBOX Authenticator Vault (`authenticator.keybox.fyi`)

This is the product-specific DPIA for the `authenticator.keybox.fyi` surface. It supplements and supersedes the `shystore-v1` SDK DPIA (`DPIA_CONFIDENTIAL_STORE_KEYLESS_RECOVERY.tex`) for TOTP/FIDO2 authenticator deployments.

TOTP/FIDO2 EXTENSION — `authenticator.keybox.fyi`

This section applies to `shyconfig.store.secret_categories` entries `auth_seed_totp` and `auth_seed_fido2`. It supplements the generic confidential-store DPIA above.

Product Description and Competitive Context

The authenticator surface at `authenticator.keybox.fyi` stores TOTP base32 secrets and FIDO2/WebAuthn credentials in the shystore vault. It competes with Google Authenticator, Authy, and 1Password TOTP. The primary privacy differentiation is structural non-enumeration: unlike all named competitors, no single party can enumerate which services a user is protecting.

Competitor	Recovery model	Operator enumeration
Google Authenticator	Device-bound; no cloud backup	N/A (no cloud)
Authy	Cloud backup; master password required	Authy holds full n
1Password TOTP	Vault; master password + secret key	1Password holds e
KEYBOX authenticator	Cognito fallback (primary); biometric reveal-all (break-glass)	Structural non-

Special Category Assessment

TOTP seeds and FIDO2 credentials are not special-category personal data under GDPR Art. 9(1). They are, however, security-critical: unauthorised disclosure enables impersonation on all services the user protects. The legal basis is Art. 6(1)(b) (contract performance — user stores their own authenticator seeds to manage their 2FA). No Art. 9 assessment is required unless the protected services themselves involve special-category processing.

Structural Non-Enumeration — the Two-List Invariant Benefit

In all single-party authenticator products, a compelled disclosure or provider breach yields the complete mapping: *user X protects services {GitHub, Google, bank, employer}*. This mapping is high-value for targeted attacks (reveals the full scope of an individual’s online accounts) and for profiling (employer, financial, health service usage is inferable from TOTP registrations).

In the KEYBOX authenticator, canonical state contains sealed seed blobs (List 1) and identity commitment hashes (List 2) with no join between them. The reconciling authority holds the off-chain linkage (identity hash $\rightarrow$ secret identifiers). A canonical state breach therefore yields sealed blobs and identity hashes with no derivable mapping between account holder and protected services. Enumerating which services a user protects requires *both* the reconciling authority’s

off-chain linkage *and* the sealer key. This is the two-list structural invariant applied to the authenticator domain.

Recovery Model — Two Tiers

Tier	Mechanism
Primary	operator_sealer: Cognito authentication causes the reconciling authority to re-issue the sealer key
Break-glass	Biometric re-derivation (Didit): full vault reveal including TOTP seeds; resolves the circular-dependency

Circular dependency analysis. If a user’s Cognito MFA is configured as TOTP-only and their only TOTP app is KEYBOX, losing their device creates a circular dependency: they need the TOTP to access Cognito, but the TOTP is in the vault they need Cognito to open. The biometric break-glass path resolves this without requiring a memorised master password. The biometric re-derivation reveals all vault contents, including the Cognito TOTP, after which the user logs into Cognito normally.

Operator obligation: Cognito must be configured with at least one non-TOTP fallback MFA method (email OTP, SMS, or passkey) so that the biometric break-glass is a genuine last resort rather than the primary recovery path.

Art. 17 Erasure for TOTP Seeds

Art. 17 erasure for TOTP seeds follows the same sealer-deletion path verified for shystore in the ERASURE section (*VERIFIED run 26369476939*): the reconciling authority deletes the sealer key mapping for the target secretId; the canonical sealed blob persists but is permanently undecryptable. The user is also instructed to remove the keybox entry from the target service’s MFA settings (the relying party retains the TOTP registration independently).

TOTP Residual Risk

Risk	Control
Reconciling authority enumerates user’s service list	Structural non-enumeration (two-list invariant); reconciling authority off-chain store
Sealer key compromise → all TOTP seeds exposed	Sealer key in reconciling authority off-chain store; a
Circular dependency → permanent vault lockout	Biometric break-glass breaks the loop; Cognito non-
Relying-party TOTP registration not removed on erasure	Operator runbook instructs user to remove keybox

TOTP extension verdict: The shystore structural layer provides meaningful privacy improvement over all named competitors via structural non-enumeration. TOTP seeds are not special-category data; Art. 6(1)(b) is sufficient. Production readiness requires: (1) Cognito configured with at least one non-TOTP fallback MFA method; (2) biometric break-glass tested

end-to-end on the authenticator surface; (3) operator runbook documenting the relying-party de-registration step for erasure requests.